

Mobile identity-verification plugin

Security assessment pack — framework inventory and data flows

Component: cordova-plugin-nfc-document-reader v1.0.0 · **Commit:** b09c7d0 · **Prepared:** 28 September 2026
For: Information Security assessment · **Owner:** Innovation Department, Al Salam Bank
Classification: Internal

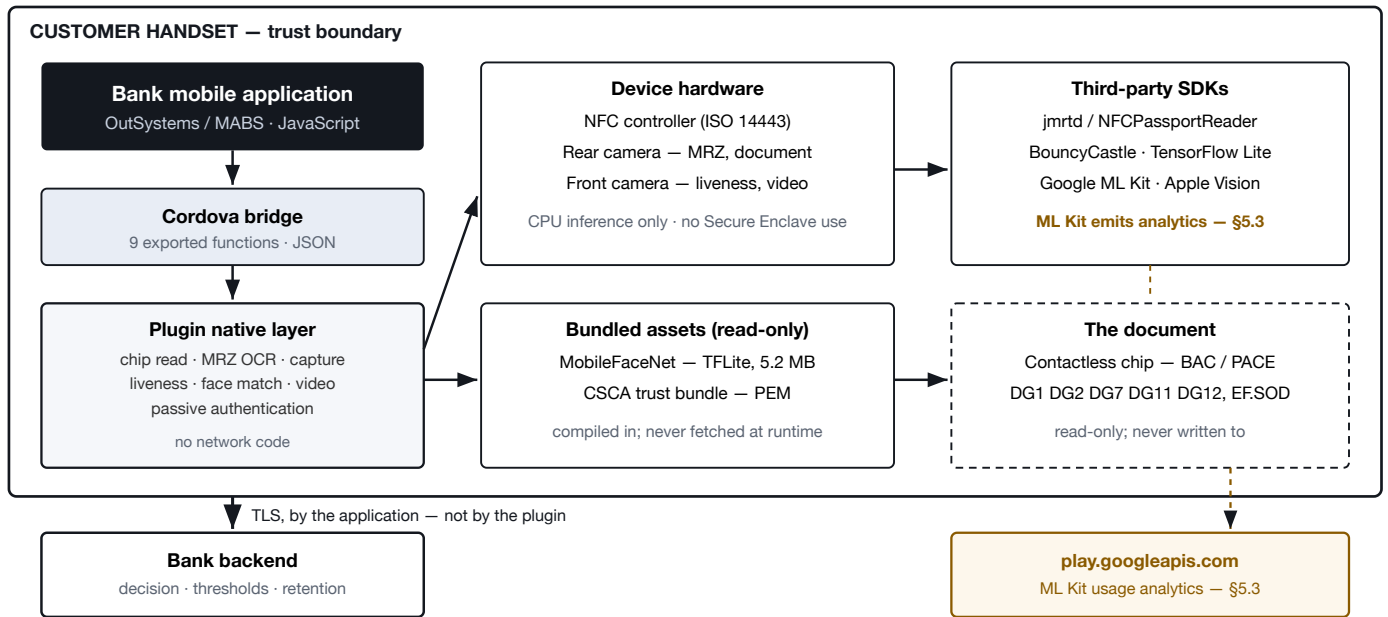
1. What this component is, and what it is not

A Cordova plugin embedded in the bank's mobile application. It reads ICAO 9303 electronic identity documents (passports and national ID cards) over NFC, scans the printed machine-readable zone with the camera, photographs the document, runs a challenge–response liveness check, and compares the holder's face against the portrait stored on the document's chip.

It is a data-collection and evidence-gathering component. It is not a decision engine. It returns measurements — a chip payload, a similarity score, a set of checks that passed or failed — to the host application, which forwards them to the bank's backend. The accept/reject decision, and every threshold behind it, lives in the backend and is deliberately not shipped in the app.

Property	Value
Execution context	In-process native code inside the bank's own mobile application
Processing location	Entirely on the customer's handset
Server-side components	None. The plugin has no backend of its own.
Outbound network connections made by the plugin	None — see §5
Data persisted by the plugin	None beyond transient temporary files, deleted within the same call
Platforms	Android (Java), iOS 15.5+ (Swift 5)

2. Component architecture



Everything inside the outer box runs on the handset. The only two arrows leaving it are the application's own TLS call to the bank, and Google ML Kit's analytics — the latter is not initiated by plugin code.

3. Third-party framework inventory

Versions are taken from `plugin.xml` and from a resolved `Podfile.lock` of an actual build, not from documentation.

3.1 Android

Library	Version	Licence	Function
<code>org.jmrtd:jmrtd</code>	0.7.42	LGPL 3.0	ICAO 9303 protocol: BAC/PACE, EFSOD, data groups
<code>net.sf.scuba:scuba-sc-android</code>	0.0.26	LGPL 3.0	Smart-card transport beneath jmrtd
<code>org.bouncycastle:bcprov-jdk18on</code>	1.78	MIT-style	Cryptography for passive authentication
<code>edu.ucar:jj2000</code>	5.2	BSD-style	JPEG 2000 decoding of the DG2 portrait
<code>com.google.mlkit:text-recognition</code>	16.0.0	Google ToS	MRZ OCR, document evidence check
<code>com.google.mlkit:face-detection</code>	16.1.7	Google ToS	Liveness challenges, face cropping
<code>androidx.camera:*</code>	1.3.1	Apache 2.0	Camera preview, frame analysis, video recording
<code>androidx.appcompat:appcompat</code>	1.6.1	Apache 2.0	Activity theming
<code>org.tensorflow:tensorflow-lite</code>	2.14.0	Apache 2.0	Face-match model inference

3.2 iOS

Pod	Resolved	Licence	Function
<code>NFCPassportReader</code>	1.1.9	MIT	ICAO 9303 over CoreNFC
<code>GoogleMLKit/FaceDetection</code>	8.0.0	Google ToS	Liveness challenges, face cropping
<code>TensorFlowLiteSwift</code>	2.14.x	Apache 2.0	Face-match model inference

Pulled in transitively and therefore present in the shipped binary: `GoogleDataTransport 10.1.0`, `GoogleUtilities 8.1.0`, `GoogleToolboxForMac 4.2.1`, `GTMSessionFetcher/Core 3.5.0`, `MLKitCommon 13.0.0`, `MLKitFaceDetection 7.0.0`, `MLKitVision 9.0.0`, `MLImage 1.0.0-beta7`, `nanopb`, `PromisesObjC`.

Apple frameworks used directly, with no third party involved: `CoreNFC`, `Vision` (all OCR on iOS), `AVFoundation`, `UIKit`, `CoreGraphics`, `ImageIO`. *OCR on iOS is Apple Vision, not ML Kit — and Vision recognises Arabic, which ML Kit has no model for.*

3.3 Bundled model

Property	Value
Model	MobileFaceNet, TensorFlow Lite, 5.2 MB, compiled into the app
Input / output	112 × 112 RGB → 192-dimensional embedding
Comparison	Cosine similarity, computed on-device
Decision threshold	Not present in the plugin. The similarity is returned; the backend decides.
Provenance	src/models/PROVENANCE.md — model governance sign-off outstanding

4. Processing flow

`captureAndReadNFC()` — the full chain, one callback



Why this order

The MRZ must be read first because it derives the chip access key. The chip must be read before the photographs, so the print-versus-chip comparison happens while the customer still holds the document.

Single JSON result → host application → bank backend over the application's own TLS channel

document fields · DG2 portrait · passive-authentication verdict · MRZ/chip comparison · liveness result
challenge frames · session video · face-match similarity (a number, not a decision) · document photographs
Nothing is written to durable storage by the plugin. Temporary video files are deleted within the same call.

The other eight exported functions are subsets of this chain and can be called individually.

5. Network egress — the assessment question

NO EGRESS Plugin code opens no network connections

Every network primitive on both platforms was searched for (`URLConnection`, `URLSession`, `dataTask`, `openConnection`, `Socket`, `http://`, `https://`). There are no matches in the plugin's source. No document data, chip data, biometric data or image ever leaves the handset by an action of this component.

5.1 Change history — a removed exfiltration path

Until commit a94c3b1 (28 September 2026) this was not true, and assessors reviewing an earlier build must treat it as a finding.

Earlier revisions POSTed **every NFC read failure** to a third-party Supabase project belonging to the plugin's original developer, on both platforms. The payload carried a partially masked document number (1139***06), a partially masked date of birth (97***2) and expiry, the host application's bundle identifier, the handset model and OS build, chip protocol details, and up to 2,000 characters of reader internals. The endpoint and its API key were XOR-obfuscated in source, with an accompanying comment stating the purpose was to prevent extraction from a decompiled build.

The masking did not anonymise the data. Four leading and two trailing digits of a nine-digit document number leave one thousand candidates; a birth year and a bank's bundle identifier reduce that to one individual. The network path has been deleted — not disabled behind a configuration flag — and the diagnostic loggers now write to the device log only, with the MRZ arguments deliberately never written.

5.2 Residual egress that is not ours

PRESENT Google ML Kit emits usage and diagnostic analytics

ML Kit performs inference on-device — no face or document is uploaded for processing. However the SDK reports usage and diagnostic data to Google. Evidence taken from the pods resolved for this build, not from documentation:

- `MLKitCommon.framework` contains the endpoints `https://play.googleapis.com/log` and `/log/batch`, and a class `MLKAnalyticsLogger`.
- It depends on `GoogleDataTransport`, whose Apple privacy manifest declares collection of `OtherDiagnosticData` for Analytics.
- **Google's own privacy manifest for `MLKitFaceDetection`** declares collection of: `DeviceID`, `OtherUserContent`, `OtherDiagnosticData`, `PerformanceData`, `ProductInteraction`, `OtherDataTypes`. `NSPrivacyTracking` is false and no tracking domains are declared.

OtherUserContent in a face-detection SDK is the item requiring clarification from Google before any statement that no data leaves the device is signed. No comprehensive opt-out is documented for standalone ML Kit; `FIREBASE_ANALYTICS_COLLECTION_ENABLED` governs a different component.

5.3 Options available to eliminate it

Option	What it involves	Assessment
Remove ML Kit from iOS	Apple Vision already performs all OCR on iOS and also detects faces, landmarks and head pose on-device with no analytics component. Vision does not expose smile and eye-open probabilities, so those must be derived from eye and mouth landmarks, and the liveness thresholds recalibrated.	Well-understood work. Removes the last third-party network component from the iOS build.
Remove ML Kit from Android	ML Kit supplies both the OCR and the face detection there. Replacement means bundling a text recogniser and a face detector as TFLite models.	Substantially larger, with a model-governance question attached to each model.
Network policy	ML Kit's traffic goes to <code>play.googleapis.com</code> , which a managed-device policy can observe and block.	A mitigation, not a fix. Whether it suffices is the bank's decision.

6. Data handled, and where it goes

Data	Class	Source	Destination and lifetime
MRZ (document number, DOB, expiry)	PII	Camera OCR	In memory; returned in the result. Used to derive the chip access key.
Chip data groups DG1, DG11, DG12	PII	NFC	In memory; returned in the result.
DG2 facial image	Biometric	NFC	In memory; returned base64 in the result.
DG7 signature image	PII	NFC	In memory; returned base64 in the result.
Liveness portrait and challenge frames	Biometric	Front camera	In memory; compressed and returned base64.
Liveness session video	Biometric	Front camera	Temporary file in app cache, deleted immediately after encoding into the result.
Document photographs	PII	Rear camera	In memory; compressed and returned base64.
Face-match similarity	Derived	On-device TFLite	A number in the result. No threshold applied.
Diagnostic error detail	Technical	Reader internals	Device log only. MRZ values deliberately excluded.

Consequence for the bank

The plugin hands biometric data to the host application in a single JSON payload. **Everything that matters for retention, encryption at rest, access control and consent is therefore a property of the application and the backend, not of this component.** A payload can exceed 1 MB; it must be treated as biometric personal data from the moment the callback fires.

7. Cryptography

Where	Mechanism	Notes
Chip access	BAC (3DES) or PACE (ECDH/AES)	ICAO 9303 standard; PACE preferred and negotiated automatically. The protocol reports which was used.
Secure messaging	Per ICAO 9303	Provided by jmrttd / NFCPassportReader, not reimplemented.
Passive authentication	CMS SignedData over EF.SOD; SHA-1/SHA-256 data-group hashes	BouncyCastle on Android; platform crypto on iOS.
Trust anchors	CSCA X.509 certificates, PEM bundle compiled into the app	Never fetched at runtime. See §8.
Transport to the bank	Not in scope	The plugin performs no transport. TLS is the application's responsibility.
Key material held by the plugin	None	No secrets, no API keys, no credentials in the source after the change in §5.1.

8. Trust model for document authenticity

Passive authentication decomposes into three independent checks, each reported separately rather than collapsed into one boolean:

Check	Reported as	Meaning
SOD signature valid	sodSignatureVerified	The Document Signer's signature over EF.SOD verifies.
Data-group integrity	dataIntegrityVerified	Every data group hashes to the value EF.SOD records.
Issuer trusted	issuerTrusted	The Document Signer chains to a CSCA in the bundled trust store.

The first two checks pass for a forger who signs their own data with their own certificate. Only the third makes the result mean "signed by the state that claims to have issued this document". Without a CSCA bundle installed the status is `notVerified / NO_TRUST_ANCHORS` — not a failure, but not evidence of authenticity either. **A CSCA bundle is not currently installed.**

9. Security controls: what each proves, and what it does not

Control	Establishes	Does not establish
Chip read (BAC/PACE)	The document carries a genuine, readable MRTD chip whose access key matches the printed MRZ.	Anything about the person presenting it.
Passive authentication	The data groups are byte-for-byte what the issuer signed, and the signer chains to a trusted CSCA.	Not clone detection. A bit-perfect copy of a genuine chip passes. Chip Authentication detects cloning; it is reported but not relied upon.
MRZ ↔ chip comparison	The print and the chip agree across seven fields, with a per-field edit distance.	A mismatch may equally be OCR misreading worn print — it is a finding for a human, not proof of fraud.
Document evidence check	The photograph shows the document that was just read — MRZ shape plus identifiers taken from the chip.	Not liveness of the document. Cannot distinguish a card from a photograph of a card or one displayed on a screen.
Liveness challenges	A printed photograph or a still image did not pass. Four single-action challenges by default (blink, smile, turn left, turn right) in a randomised order. Four compound challenges requiring two simultaneous actions exist but are disabled pending calibration.	Not defeated: a replayed video, an injected or virtual camera feed, or a 3D mask. There is no presentation-attack detection. With four challenges drawn from a pool of four, the randomisation is of order only, not of which challenges are asked.
Session video	An auditable record of what the customer actually did.	No improvement to attack detection — a replay attack is simply recorded.
Face match	A cosine similarity between the liveness portrait and the DG2 chip portrait, computed on-device.	Not a decision. No threshold is applied in the app; the backend decides.

10. Permissions and entitlements

Platform	Declared	Purpose
Android	<code>android.permission.CAMERA</code>	MRZ, document capture, liveness
Android	<code>android.permission.NFC</code>	Chip reading; NFC hardware declared required
Android	<i>No INTERNET permission required by the plugin</i>	Consistent with §5
iOS	<code>NSCameraUsageDescription</code>	As above
iOS	<code>NFCReaderUsageDescription</code>	Chip reading
iOS	<code>com.apple.developer.nfc.readersession.formats</code>	Entitlement; App ID needs NFC Tag Reading enabled
iOS	<code>...iso7816.select-identifiers</code>	The MRTD application identifier

No microphone permission is requested. Audio is never recorded, including during video capture — a liveness check has nothing to learn from it and recording a customer's voice is a consent question nobody has asked.

11. Open items for the assessment

#	Item	Status / owner
1	Clarify with Google what OtherUserContent covers in the ML Kit face-detection privacy manifest	Open — blocks any unqualified no-egress statement
2	Decide whether to remove ML Kit from the iOS build (§5.3)	Open — Innovation / InfoSec
3	Install and govern a CSCA trust bundle; without it issuer trust is never established	Open — see src/cscsca/README.md
4	Model governance sign-off for MobileFaceNet	Open — Model Risk
5	Calibrate the backend face-match threshold; one genuine pair observed at 0.7474	Open — backend
6	Retention, consent and access control for biometric payloads and session video	Open — Legal / Compliance / Data Protection
7	Liveness compound-challenge thresholds not yet calibrated against real faces; the compound challenges are disabled by default until they are	Open — first device pilot
8	No penetration test or presentation-attack test has been performed on this component	Open — InfoSec

Statement of verification status

The framework inventory, the absence of plugin network code, and the ML Kit privacy-manifest findings in this document were verified by inspection of the source and of a resolved dependency build on 28 September 2026. Both platforms compile against real dependencies. **The plugin has not been executed on a physical handset for the changes in this revision, and no independent security testing has been carried out.**